

AI 가계부

영수증 한 장으로 끝나는 똑똑한 가계 관리

Product Requirements Document (PRD) v1.0

"AI가 후보를 제안하고, 결정은 당신이 한다."

OCR + LLM(OpenAI gpt-4o-mini) 기반 승인형(human-in-the-loop) 가계부

문서 정보

문서 버전	v1.2
작성일	2026-05-08
제품 코드	ai-household-ledger
스택	Next.js · TypeScript · Supabase · Tesseract.js · OpenAI gpt-4o-mini · Vercel

01. Executive Summary

“가계부, 또 적다 말았다.” — 이 문장으로 시작하지 않는 가계부 앱은 없습니다.
AI 가계부는 그 ‘적는다’의 단계를 통째로 없앱니다. 영수증을 찍거나 카드 명세 캡처를 올리면, OCR과 LLM(OpenAI gpt-4o-mini)이 거래 후보를 만들어 카드 형태로 보여주고, 사용자는 승인 한 번으로 가계부에 반영합니다.
동시에 우리는 두 가지 원칙을 절대 양보하지 않습니다.

AI는 후보만 만든다. 결정은 사용자가 한다.

AI가 자동 추출한 거래는 transactions 테이블에 직접 들어가지 않습니다. 사용자가 카드 단위로 확인·수정·승인하기 전까지는 ‘후보(candidate)’ 상태로만 존재합니다. 이 인간-루프(human-in-the-loop) 구조가 ‘AI가 잘못 적은 가계부’의 위험을 원천적으로 차단합니다.

내보내는 모든 텍스트는 마스킹 모듈을 강제 통과한다.

OCR 원문은 7일 후 자동 폐기됩니다. 카드/계좌/주민/전화/사업자/승인번호는 단일 마스킹 모듈을 통과하지 않으면 어떤 저장소·로그·AI(OpenAI) 요청에도 들어가지 않습니다. AI에 보내는 ‘사용자 학습 힌트’는 정규화된 상위 N개 키워드뿐입니다. Supabase Row Level Security로 사용자 간 데이터는 행 단위로 격리됩니다.

≤ 3초

영수증 1장 → 후보 카드

0개

AI 자동 저장 항목

7일

OCR 원문 보관 한도

100%

사용자 데이터 RLS 격리

02. 왜 또 가계부가 필요한가

기존 가계부 앱이 풀지 못한 4가지 문제

문제	사용자가 실제로 겪는 일	기존 앱의 한계
입력 마찰	영수증·카드·현금이 뒤섞이는데 매번 손으로 입력해야 한다.	타이핑 위주. OCR을 제공해도 결과를 그냥 저장해버려 잘못 들어가면 되돌리기 힘들다.
자동화의 두려움	은행·카드사 연동은 편하지만 비밀번호·공동인증서를 넘기는 것이 부담스럽다.	스크래핑/오픈뱅킹은 인증 권한 위임이 필요. 데이터가 어디서 어떻게 처리되는지 불투명.
프라이버시 불안	내 영수증·결제내역은 가장 사적인 데이터에 가깝다.	마스킹 강제·원문 폐기 정책 없이 원문 텍스트를 그대로 클라우드/외부 LLM에 보낸다.
학습되지 않는 분류	'스타벅스', 'GS25'를 매번 같은 카테고리로 다시 분류한다.	규칙이 사용자에게 맞춰 자라지 않는다. 어제 정한 분류가 내일 또 묻는다.

우리는 이 문제를 정확히 거꾸로 푼다

입력 마찰은 사진 한 장으로, 자동화의 두려움은 '승인형' UX로, 프라이버시 불안은 PII 마스킹 강제 + 정규화 키워드만 전송 + 원문 7일 폐기 + 선택형 100% 로컬 모드로, 학습되지 않는 분류는 사용자별 학습 규칙으로 푹니다.

문제 영역	우리의 해법
입력 마찰	영수증 카메라 업로드 → OCR → AI 후보 카드 → 한 번의 승인. 평균 3초.
자동화 두려움	은행 비밀번호를 받지 않습니다. 오직 사용자가 올린 이미지/CSV/XLSX만 처리합니다.
프라이버시	AI(OpenAI gpt-4o-mini)에는 마스킹된 텍스트 + 정규화 키워드만 전송. 원문 7일 자동 폐기. response_format=json_object로 부수적 데이터 노출 차단.
학습 누적	사용자가 수정·승인할 때마다 가맹점·카테고리·결제수단 학습 규칙이 갱신됩니다.

03. 솔루션 — 승인형 AI 가계부

한 줄 정의

“영수증·카드 캡처·문자 결제내역 이미지를 올리면, OCR과 LLM(OpenAI gpt-4o-mini)이 거래 후보를 만들고, 사용자가 확인·수정·승인한 항목만 가계부에 저장되는 승인형 AI 가계부 웹앱.”

핵심 가치 3가지

- AI는 일을 줄이고, 결정은 빠앗지 않는다. AI는 OCR과 LLM으로 90%의 입력 노동을 대신하지만, transactions에 무엇을 남길지는 100% 사용자가 정합니다.
- 쓸수록 똑똑해진다. 사용자의 수정·승인 기록이 user_correction_logs와 학습 규칙에 쌓여, 같은 가맹점·같은 패턴은 다음번에 더 빠르고 정확하게 처리됩니다. LLM 모델 자체를 재학습시키지 않습니다 — 앱이 사용자 패턴을 ‘힌트’로 주입하고, 동일 입력은 analysis_cache로 호출 자체를 생략하는 구조입니다.
- 데이터 주권은 사용자에게. 원본 이미지/원문 텍스트는 사용자 폴더에만 저장되고, 7일 후 OCR 원문은 자동 폐기됩니다. JSON/CSV 전체 내보내기과 계정 완전 삭제(타이핑 확인)는 언제든지 가능합니다.

핵심 흐름 한 그림

#	단계	무슨 일이 벌어지는가
①	업로드	영수증·카드 명세 캡처(다중·드래그·카메라) 또는 CSV/XLSX
②	OCR (클라이언트)	Tesseract.js로 추출 → 마스킹 → 미리보기에서 사용자 직접 수정 가능
③	학습 사전매칭	merchant/category/payment 학습 규칙과 analysis_cache 조회
④	AI 분석	OpenAI gpt-4o-mini가 마스킹 텍스트 + 사용자 힌트로 후보 JSON 생성 (response_format=json_object · zod 검증)
⑤	후처리	환각 검증(substring), 패턴 비교로 confidence 보정, 중복 검사
⑥	후보 카드	candidate 상태로 표시 — 가맹점/금액/카테고리/결제수단/경고 배지
⑦	승인	단건 또는 일괄 승인. 의심·중복은 일괄에서 자동 제외
⑧	최종 저장 + 학습	transactions insert + correction_logs/learning_rules 갱신

04. 왜 이 제품을 ‘반드시’ 써야 하는가

다른 가계부와 우리는 이렇게 다르다

비교 축	은행연동/스크래핑 형	수기 입력형	범용 OCR+LLM 앱	AI 가계부 (우리)
인증 권한	은행 비밀번호·공동 인증서 위임	없음	없음	없음 — 사용자가 올린 이미지/파일만
AI 자동 저장	자동 분류 + 자동 저장	—	AI 결과 그대로 저장	금지 — 승인 전엔 candidate
프라이버시	스크래핑 트래픽이 외부로	안전하지만 마찰 큼	원문을 외부 LLM에 그대로 전송	단일 마스킹 모듈 강제 통과 + 정규화 키워드만 전송 + 7일 원문 폐기
원문 보관	장기 보관	해당 없음	장기 보관 가능	OCR 원문 7일 자동 폐기
학습/개인화	은행 분류 의존	없음	범용 모델, 개인화 약함	사용자별 학습 규칙 + 캐시
가족 공유	일부 지원, write 권한 광범위	없음	거의 없음	read 공유 + write는 본인 행만
월 비용	유료 구독 일반적	무료	API 호출량 비례	무료 플랜 운영 가능

핵심 차별 포인트 5가지

- 승인형 AI(Human-in-the-loop): AI가 만든 거래는 항상 ‘후보’. 자동 저장이 단 1건도 일어나지 않도록 코드와 RLS로 강제.
- 마스킹 강제 + 빠른 추론: OpenAI gpt-4o-mini로 빠르고 정확한 후보 생성. 단, 외부에 나가는 모든 텍스트는 lib/security/masking 단일 모듈을 강제 통과합니다. response_format=json_object로 응답을 JSON 객체로 고정하고, max_tokens:temperature(0.1)로 출력 변동성을 최소화합니다.
- 단일 마스킹 모듈: 카드/계좌/주민/전화/사업자번호·승인번호는 단 하나의 모듈을 통해서만 저장·로그·AI 요청에 노출됩니다. 단위 테스트로 회귀 방지.
- 학습 가속 + 비용 절감: analysis_cache(input_hash) 적중 시 LLM 호출 자체를 생략합니다. 자주 보던 영수증은 추가 토큰 소모 없이 즉시 후보가 만들어집니다.
- 다채널 입력: 카메라/드래그/다중 업로드 + CSV/XLSX 가져오기 (헤더 자동 매핑·미리보기 후 일괄 커밋).

05. 타겟 사용자

우리는 이 사람들을 위해 만든다

페르소나	특징	상황	말버릇
P1 · 가계 자동화에 지친 직장인	20대 후반 ~ 40대	한 달에 영수증·카드 결제 50건 이상. 가계부 시작했다가 늘 일주일 안에 포기.	“손은 그만 쓰고 싶다. 하지만 은행 비밀번호는 절대 못 넘긴다.”
P2 · 프라이버시 민감 사용자	보안·개발·의료·법조계	외부 LLM에 마스킹 없이 원문을 보내는 것 자체가 정책 위반.	“마스킹된 텍스트와 정규화 키워드만 전송된다면 써볼 의향이 있다.”
P3 · 가족 공동 가계 운영자	신혼/육아 가구	부부가 각자 카드를 쓰지만 한 가계부에 모아길 원함. 단, 서로의 기록을 ‘덮어쓰지’는 않길 원함.	“같이 보고 싶지만, 내가 쓴 건 내가 책임진다.”
P4 · 사업자/프리랜서	자영업·1인 사업자	영수증·카드/계좌 캡처를 매월 정리해 세무사에게 넘겨야 함.	“CSV/XLSX로 내보낼 수만 있다면 큰 도움이다.”

우리는 이런 사용자들을 일부러 빼고 시작했다

- “알아서 다 해주는” 100% 자동 분류 + 자동 저장을 원하는 사용자 — 우리는 승인 클릭을 절대 없애지 않습니다.
- 은행 직접 연동·실시간 잔액 추적이 핵심인 사용자 — 본 제품은 이미지/파일 기반 가계부입니다.
- 이런 요구는 로드맵에서도 의도적으로 제외하여, ‘사용자 결정권 + 프라이버시’라는 핵심 가치를 흐리지 않습니다.

06. 핵심 기능

6.1 입력 — 다채널 업로드

- 이미지 업로드: 드래그&드롭, 다중 선택, 모바일 카메라 캡처, jpg/png/webp/pdf
- OCR (클라이언트 측): Tesseract.js로 추출 → 서버 저장 시 한 번 더 마스킹. Vercel 함수 시간 제약 회피.
- OCR 미리보기 + 직접 수정: 사진이 흐릿하면 사용자가 텍스트를 손으로 고친 뒤 재분석
- CSV/XLSX 가져오기: 카드 명세/은행 거래내역 헤더 자동 감지 → 컬럼 매핑 → 미리보기 → 일괄 커밋
- 저장 경로: Supabase Storage {user_id}/yyyy/mm/uuid.ext — 사용자별 폴더 격리

6.2 분석 — LLM 호출 + 학습

- OpenAI gpt-4o-mini — response_format=json_object · temperature 0.1 · max_tokens 1500 · 60초 타임아웃. 입력은 항상 maskAll() 통과한 텍스트.
- 실패 처리: HTTP 오류·타임아웃·JSON 파싱 실패 시 1회 자동 재시도 → 그래도 실패하면 ai_extraction_jobs.status='failed'로 기록하고 사용자에게 '수동 입력으로 진행하시겠어요?' 회복 경로 제공.
- 분석 전 사전 매칭: merchant_learning_rules / category_learning_rules / payment_method_learning_rules / analysis_cache 조회 → 캐시 적중 시 LLM 호출 생략.
- 프롬프트 주입: 마스킹된 OCR 텍스트 + '사용자 힌트(상위 N개 정규화 키워드)'만 전송.
- JSON 검증: zod 스키마로 형식 검증. 실패 시 1회 재시도.
- 환각 검증: AI가 생성한 raw_text_basis가 OCR 텍스트에 substring으로 실제 존재하는지 점검.
- 분석 후 보정: 사용자 평소 패턴과 다르면 confidence 하향 + warning, 같으면 보강.
- 중복 검사: 최근 30일 transactions와 (날짜+금액+가맹점) 정규화 비교 → none/suspected/duplicate.

6.3 승인 — 인간 결정 강제

- 후보 카드 UI: 가맹점·금액·카테고리·결제수단·신뢰도·경고 배지·중복 상태
- 단건 액션: 승인 / 수정 후 승인 / 제외
- 일괄 승인: 데스크톱 표 + 모바일 sticky bottom 바. 의심·중복은 일괄 대상에서 자동 제외.
- 승인 시: transactions insert (is_ai_generated=true, is_confirmed=true) + correction_logs + 학습 규칙 갱신
- 자동 저장 금지: '반복 패턴이라 확실해 보임'도 자동 저장하지 않습니다. 항상 사용자 클릭 1회.

6.4 운영 — 가계부 본연의 기능

- 거래 CRUD: PC 표 / 모바일 카드 자동 전환, 검색·유형 필터, 추가/수정/삭제
- 카테고리·결제수단 관리: 색상 프리셋, 결제수단은 마지막 4자리만 입력 강제(클라 maxLength + zod)
- 대시보드: 월 범위 집계, MonthlyBars, 최근 거래, 카테고리 상위 + AI 통계 4카드
- 예산: 카테고리별/전체 월 예산. 진행률 safe / caution / over (기본 임계 80%) + 대시보드 위젯
- 고정지출 후보: 90일 반복 지출 자동 감지(평균/안정성)로 '고정지출' 제안
- 가족 공유(Households): 같은 household 멤버 read 공유 + write는 본인 행만 (안전 우선) + 7일 유효 초대 코드
- 내보내기: /api/export(JSON 전체), /api/export/transactions(CSV)
- 계정 삭제: 타이핑 확인. 거래/파일/OCR/AI 결과/학습데이터 완전 삭제

6.5 모바일·접근성

- PWA: 홈 화면 설치, skipWaiting + clientsClaim으로 새 SW 즉시 활성화
- 반응형: PC 사이드바·표·다열 카드 / 모바일 하단 네비·카드 리스트·큰 업로드/승인 버튼
- 한 손 조작: 일괄 승인 sticky bar(BottomNav 위 56px), 모바일에서 가로 스크롤 차단
- 접근성: 본문 진한 회색, 핑크 위 텍스트는 흰색, AA 대비 점검
- E2E (Playwright): 6개 뷰포트(360/390/768/1024/1280/1440)에서 핵심 12케이스 자동 점검

07. 사용자 여정

‘영수증 한 장’ 시나리오 — 21초 안에 끝나는 가계부

시간	사용자가 보는 것 / 시스템이 하는 일
00:00	마트에서 결제. 영수증을 받는다.
00:03	AI 가계부 PWA를 홈 화면에서 연다 (설치돼 있으면 즉시 실행).
00:05	‘업로드’ 카메라 버튼 → 영수증 촬영. 다중 촬영도 가능.
00:09	Tesseract.js가 클라이언트에서 OCR을 돌리는 동안 미리보기를 본다. 흐리면 텍스트를 손으로 고친다.
00:12	마스킹 + 학습 사전 매칭 → ‘GS25’ 자주 가는 곳: 카테고리 ‘식비/편의점’이 미리 채워진다.
00:15	OpenAI gpt-4o-mini가 후보 JSON을 만든다. (캐시 적중이면 LLM 호출 생략)
00:18	후보 카드 1장이 뜬다. 가맹점·금액·결제수단(끝 4자리)·날짜·신뢰도·중복 상태.
00:20	사용자가 카드를 한 번 본다. ‘승인’ 탭.
00:21	transactions에 저장됨. correction_logs에 ‘approved’ 기록. 가맹점 학습 규칙 match_count++.

‘월말 카드 명세’ 시나리오 — 50건을 한 번에

- 카드사 사이트에서 월간 명세를 CSV/XLSX로 내려받는다.
- /import 페이지로 드래그. 헤더 자동 감지 → 컬럼 매핑 → 미리보기.
- 학습 규칙·중복 검사가 모든 행에 적용된다. 의심 행은 노란 배지.
- ‘일괄 커밋’ — 의심·중복은 자동 제외하고 50건 중 38건이 transactions로 이동.
- 남은 12건은 화면에 정렬되어, 사용자가 한 줄씩 검토 후 승인/수정/제외.

‘부부’ 시나리오 — 가족 공유

- 남편이 ‘우리집’ household를 만든다 → 7일 유효한 10자리 초대 코드 발급.
- 아내가 코드 입력 → 합류. 두 사람의 거래는 같은 household에서 read 공유.
- 단, 남편이 만든 거래를 아내가 임의로 수정/삭제할 수는 없다 — write는 본인 행만.
- 예산 카테고리·결제수단도 함께 보이고, 데이터 무결성은 만든이 단위로 유지된다.

08. 기술 아키텍처 요약

스택 한눈에

Framework	Next.js 14 App Router · TypeScript · Tailwind CSS
Auth	Supabase Auth (매직 링크) · middleware로 보호 라우트
DB	Supabase PostgreSQL · 모든 사용자 소유 테이블 RLS 강제
Storage	Supabase Storage · {user_id}/yyyy/mm/uuid.ext
OCR	Tesseract.js (클라 측) · 추후 PaddleOCR/Clova 어댑터 검토
LLM	OpenAI gpt-4o-mini · response_format=json_object · temperature 0.1 · 60초 타임아웃
Validation	zod 스키마 (입력/출력 모두)
Hosting	Vercel (Hobby 가능) · GitHub 자동 배포
PWA	@ducanh2912/next-pwa · skipWaiting + clientsClaim
Test	Vitest 단위 + Playwright E2E (6 viewport)
Privacy CI	gitleaks · npm audit · pre-commit

핵심 모듈 분리

계층	디렉터리	역할
app/	App Router 라우트 + API	page.tsx / route.ts. 서버에서만 service role key 접근.
components /	UI	layout / common / transactions / candidates / upload / files / settings / charts
services/	도메인 로직	transaction · candidate · ocr · extraction · learning · analytics
lib/	인프라	supabase(client/server/admin) · ocr · ai(openaiClient/prompt/extractionSchema) · security(masking) · duplicate · learning · formatting · validators · http
supabase/	마이그레이션 SQL	0001_init · 0002_storage_policies · 0003_budgets · 0004_households
tests/	검증	단위 + 하네스 + Playwright E2E

상태머신 (uploaded_files.status)

uploaded → ocr_processing → ocr_done → ai_processing → parsed (또는 failed) → approved → deleted

각 전이에 대해 RLS와 서비스 레이어가 권한·소유·중복을 검증합니다. AI 분석 실패 시 사용자에게 '수동 입력으로 진행하시겠어요?'로 회복 경로를 명확히 제공합니다.

09. 보안 · 프라이버시 · 데이터 거버넌스

9.1 마스킹 의무

항목	정책
카드번호	전체 저장 금지. 마지막 4자리와 ****-****-****-1234 형태만 허용
계좌번호	전체 저장 금지. 끝 4자리만
승인번호	전체 저장 금지. 끝 3자리만 또는 미저장
주민등록번호	원문 저장 금지. ****-****-****
전화번호	원문 저장 금지. 끝 4자리만
사업자등록번호	원문 저장 금지. 마지막 그룹만

9.2 RLS · Storage · 키 관리

- RLS: 모든 사용자 소유 테이블에 활성화. auth.uid() = user_id인 행만 select/insert/update/delete.
- Storage 정책: 사용자 폴더({user_id}/...)만 접근 가능. 폴더 경로 명명 강제.
- service role key: 서버(lib/supabase/admin.ts)에서만 사용. NEXT_PUBLIC_ prefix 금지. 빌드 산출물 grep 점검.
- secret: gitleaks pre-commit/CI. 커밋 발견 시 즉시 키 회전 + 히스토리 정리.

9.3 데이터 수명

OCR 원문은 7일 후 자동 폐기됩니다.

Vercel Cron이 /api/admin/purge-raw-text를 토큰 인증으로 호출 → RAW_TEXT_TTL_DAYS 환경변수에 따라 raw_text 컬럼만 비웁니다. 사용자는 언제든지 파일을 즉시 삭제할 수 있고, 삭제 시 Storage 객체와 OCR/AI 결과·학습 흔적이 일관되게 정리됩니다.

9.4 AI 요청 데이터 최소화

- AI 서버에 보내는 텍스트는 마스킹 + 트림 + 필요한 부분만.
- 사용자 학습 힌트는 상위 N개 정규화 키워드만 전달 — 원문 가맹점/메모는 그대로 보내지 않음.
- 전송 채널은 HTTPS. 자체 서명 인증서 사용 시 검증을 끄지 않음.
- global_learning_rules는 자동 갱신 금지. 정제·익명화 파이프라인을 통과하고 K-익명성($K \geq N$)을 만족할 때만 등재.

9.5 사용자 권리

- 전체 내보내기: /api/export — 거래·후보·파일 메타·학습 규칙까지 JSON.
- 거래 CSV 내보내기: /api/export/transactions.
- 계정 완전 삭제: 타이핑 확인 후 거래/파일/OCR/AI/학습데이터 모두 삭제.

10. 성공 지표 (KPIs)

‘이 PRD가 약속하는 결과’를 어떻게 측정할 것인가

KPI	정의 / 계산	초기 목표
입력 시간 단축	‘영수증 1장 업로드 → 후보 카드 표시’ 평균 시간(클라이언트 측 측정)	≤ 3초 (캐시 적중) / ≤ 8초 (LLM 호출)
AI 자동 저장 사고	transactions에 사용자 승인 없이 들어간 행 수	0건 (RLS:코드 양 측에서 강제)
AI 1차 정확도	AI가 만든 후보가 ‘수정 없이 승인’된 비율	60%+ (개인화 학습 누적 후)
학습 효과	동일 가맹점 재등장 시 ‘수정 없이 승인’ 비율 변화	사용 30일 후 +20%p
승인까지 클릭 수	단일 영수증 평균 클릭 수	1.0 클릭 (단건) / 1.0 클릭 (일괄 N건)
원문 보관 위반	RAW_TEXT_TTL_DAYS 초과 raw_text 수	0건
RLS 회귀	타 사용자 데이터 노출 테스트 실패 케이스	0건 (smoke:rls 자동)
월 비용	Vercel + Supabase 무료 플랜 + OpenAI gpt-4o-mini 호출 비용	캐시 적중률 50%+ 운영 시 사용자당 월 수백 원 수준

부가 지표 — 신뢰 지표

- 확신도(confidence) 0.8 이상 후보의 사용자 승인 비율
- ‘differs_from_user_pattern’ 경고가 부착된 후보의 사용자 수정 비율
- duplicate_status='suspected' 후보의 실제 중복 적중률
- AI 실패(JSON 검증·재시도 실패) 시 수동 입력으로의 완료율

11. 로드맵

11.1 이미 구현된 것 (Phase 0–11 일부)

- Phase 0–10 — 설계 19종, 프로젝트 세팅, 기본 가계부, 파일 업로드, OCR, AI 분석, 학습 데이터, 승인형 반영, 중복 검사, 통계 고도화, 보안·운영(1차), CI(typecheck/lint/vitest/build/gitleaks)
- Phase 11(고도화) 일부 — CSV/XLSX 가져오기, 예산, E2E(6 viewport), 가족 공유 1차

11.2 다음 후보 (우선순위 순)

우선	기능	가치
P1	거래/예산 등록 시 활성 가족 공유 토글 + 만드미 표시	가족 공유의 일상 사용성을 높임. 누가 어떤 거래를 만들었는지 가시화.
P2	PDF 입력(별도 위커)	Vercel 함수 시간 한계 회피. 영수증 PDF 자동 변환 흐름 확장.
P3	PaddleOCR / Clova OCR 어댑터	한글 영수증 인식을 향상 — Tesseract.js 한계 보완.
P4	소비 패턴 자동 인사이트	'이번 달 식비가 평소 대비 +28%' 같은 자동 요약 카드.
P5	예산 임계 도달 알림 (메일/푸시)	예산을 '확인하는 화면'에서 '선제 알리는 화면'으로 격상.
P6	시각 회귀 스냅샷	디자인 시스템 보호. 핵심 화면 회귀 자동 차단.

11.3 의도적으로 '하지 않을 것'

- 은행 비밀번호/공동인증서 위임을 통한 자동 스크래핑 — 가치(프라이버시)와 정면 충돌.
- 마스킹·정규화를 거치지 않은 원문 텍스트의 외부 LLM 전송 — 마스킹 강제 원칙과 충돌.
- AI 결과 자동 저장 모드('완전 자동') — '승인형'이라는 핵심 가치를 흐림.
- 사용자 PII가 들어간 global_learning_rules 자동 학습 — 자동 갱신 금지 정책.

12. 위험 · 완화

#	위험	영향	완화
R 1	AI 환각 / 정확도 저하	잘못된 후보 생성 (자동 저장은 안 됨)	zod 검증 + raw_text_basis substring 검증 + 학습 후처리 + confidence/warning 표기
R 2	AI 서버 가용성	분석 불가	AiServerStatus 배너 + OCR/학습 기반 fallback 후보 + 수동 입력 경로
R 3	Vercel 함수 시간/메모리 한계	OCR/AI 타임아웃	OCR 클라이언트 측 실행, 비동기 분리(폴링), PDF 등 무거운 작업은 별도 워커 검토
R 4	Tesseract.js 한국어 한계	영수증 인식 실패	사용자 텍스트 직접 수정 + PaddleOCR/Clova 어댑터 로드맵
R 5	민감정보 누출	PII가 로그/AI 요청에 포함	단일 마스킹 모듈 강제 통과 + 8케이스 단위 테스트 + 로그 정책
R 6	RLS 누락	타 사용자 데이터 노출	모든 사용자 소유 테이블 RLS + smoke:rls 자동 + PR 체크
R 7	service role key 노출	RLS 우회 가능	서버 전용 + NEXT_PUBLIC_ 금지 + 빌드 산출물 grep
R 8	Storage 정책 오류	타 사용자 폴더 접근	{user_id}/... 명명 + Storage 정책 단위 테스트
R 9	무료 플랜 한도(0.5GB DB / 1GB Storage)	운영 한도 초과	원본 이미지 자동 정리 옵션 + 압축 + 사용량 모니터링
R 10	다중 사용자 동시 호출 시 AI 큐 적체	응답 지연	전용 머신 + 동시 요청 큐잉/Rate Limit + 사용자별 입력 격리
R 11	시간대(KST/UTC) 혼재	월 경계 어긋남	DB UTC 저장 + 클라이언트 KST 표시 + 집계 KST 경계 변환
R 12	회귀(Regression)	기존 흐름 깨짐	단위/통합/E2E + AI 하네스 + 시각 회귀(예정)

13. 마무리 — 사용자에게 약속하는 것

‘적지 않아도 정확한 가계부’ — 그러나 ‘내 손을 떠난 가계부’는 만들지 않습니다.

AI 가계부는 입력의 95%를 자동화하지만, 마지막 5% — 무엇이 진짜 내 거래인지 결정하는 권한 — 은 코드와 RLS 양쪽에서 사용자에게 강제로 묶어둡니다.

우리의 4가지 약속

- ① 자동 저장 0건 — AI가 만든 거래는 항상 ‘후보’입니다. 단 한 번도 transactions에 직접 들어가지 않습니다.
- ② 외부에 나가는 모든 텍스트는 마스킹을 강제 통과 — OpenAI gpt-4o-mini에 보내는 입력은 항상 단일 마스킹 모듈(maskAll)을 거친 텍스트와 정규화된 학습 키워드뿐입니다. 카드/계좌/주민/전화/사업자/승인번호 원문은 어떤 경로로도 외부에 나가지 않습니다.
- ③ 7일 후 OCR 원문 자동 폐기 — 마스킹된 텍스트와 사용자가 승인한 transactions만 남습니다. 언제든지 전체 내보내기·계정 삭제 가능.
- ④ 쓸수록 빨라지고 정확해짐 — 사용자별 학습 규칙·캐시가 누적되어, 자주 가는 가맹점은 다음번에 수 초 안에 처리됩니다.

그래서 사용자는 무엇을 얻는가

- 한 달 가계부 입력에 쓰던 시간 대부분을 회수합니다.
- AI가 ‘대신 적은’ 가계부 때문에 통계가 망가질 걱정이 구조적으로 없습니다.
- 내 영수증·결제내역은 내 컴퓨터/내 계정을 거의 떠나지 않습니다.
- 가족과 함께 보지만, 누구도 내가 만든 행을 임의로 덮지 못합니다.

그리고 이 모든 것을 — 추가 비용 없이.

Vercel Hobby + Supabase Free + OpenAI gpt-4o-mini 조합만으로 다중 사용자 운영의 첫 단계가 가능합니다(캐시 적중 시 LLM 호출 생략으로 비용 추가 절감).

AI 가계부 · Product Requirements Document v1.0 · 2026-05-08 · 관련 문서: docs/PROJECT_OVERVIEW.md · ARCHITECTURE.md · DATABASE_SCHEMA.md · AI_EXTRACTION_FLOW.md · LEARNING_DATA_FLOW.md · SECURITY_PRIVACY_RULES.md · BUDGETS.md · HOUSEHOLDS.md · IMPLEMENTATION_STATUS.md · KNOWN_RISKS.md